



Anatomía de un Ciberataque Controlado

La metodología y las 6 fases críticas de una auditoría de Hacking Ético

Presentado por Carlos Noboa

El Ciclo de Vida de la Intrusión

Un proceso riguroso y predecible para identificar, validar y mitigar riesgos.





Fase 0: Planificación

Definiendo las reglas del juego para una ejecución segura y controlada.

El Enfoque (Perspectiva)

- Caja Negra: Sin conocimiento previo. Emula un atacante real ciego.
- Caja Blanca: Conocimiento total (código, usuarios, infraestructura).
- Caja Gris: Enfoque híbrido (ej. credenciales de bajo privilegio).

El Alcance (Fronteras)

Definición estricta de qué sistemas serán auditados y cuáles quedan absolutamente excluidos (ej. denegaciones de servicio o ingeniería social).

La Logística (Ejecución)

Acuerdos sobre horarios de impacto, entornos (Producción vs. Preproducción) y designación de personas de contacto técnico para incidencias.

Fase 1: Recolección de Información

Mapeando el terreno a través de fuentes abiertas y reconocimiento pasivo.

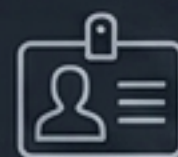


Información Tecnológica



Descubrimiento de direcciones IP, dominios, subdominios y versiones de software expuestas.

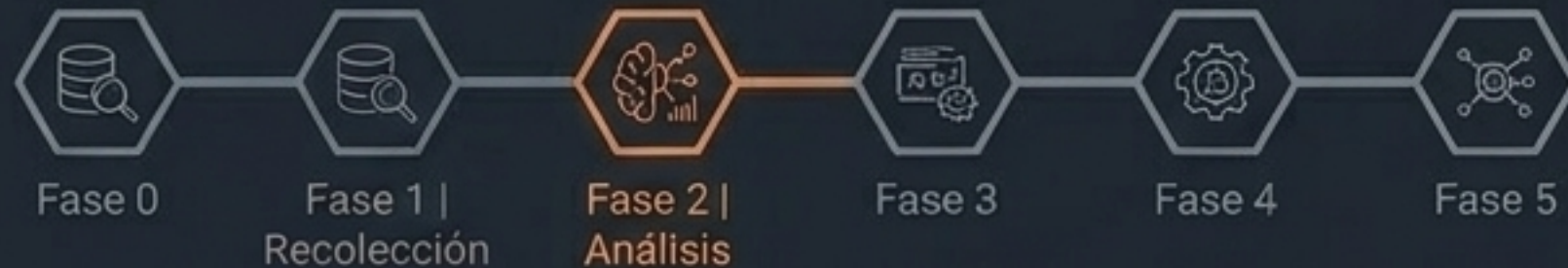
Información de Usuarios



Recopilación de direcciones de correo, filtración de credenciales, identidades y formatos de datos corporativos.

Fase 2: Análisis de Vulnerabilidades

Identificación de debilidades técnicas mediante un enfoque dual.



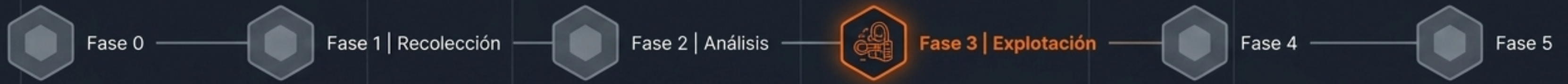
Análisis Automático

- Eficiencia temporal mediante herramientas de escaneo masivo.
- Excelentes resultados en entornos y configuraciones estándares.
- Limitación: Incapaz de detectar fallos de lógica compleja de negocio.



Análisis Manual

- Análisis exhaustivo impulsado por la creatividad y experiencia del auditor.
- Identificación de vulnerabilidades lógicas y ataques en cadena.
- Requisito esencial: Validación humana para descartar los falsos positivos del software automático.



Fase 3: Explotación de Vulnerabilidades

Transición de la teoría a la realidad técnica.



“El objetivo de la explotación no es destruir, sino confirmar la vulnerabilidad y acotar su alcance real.”

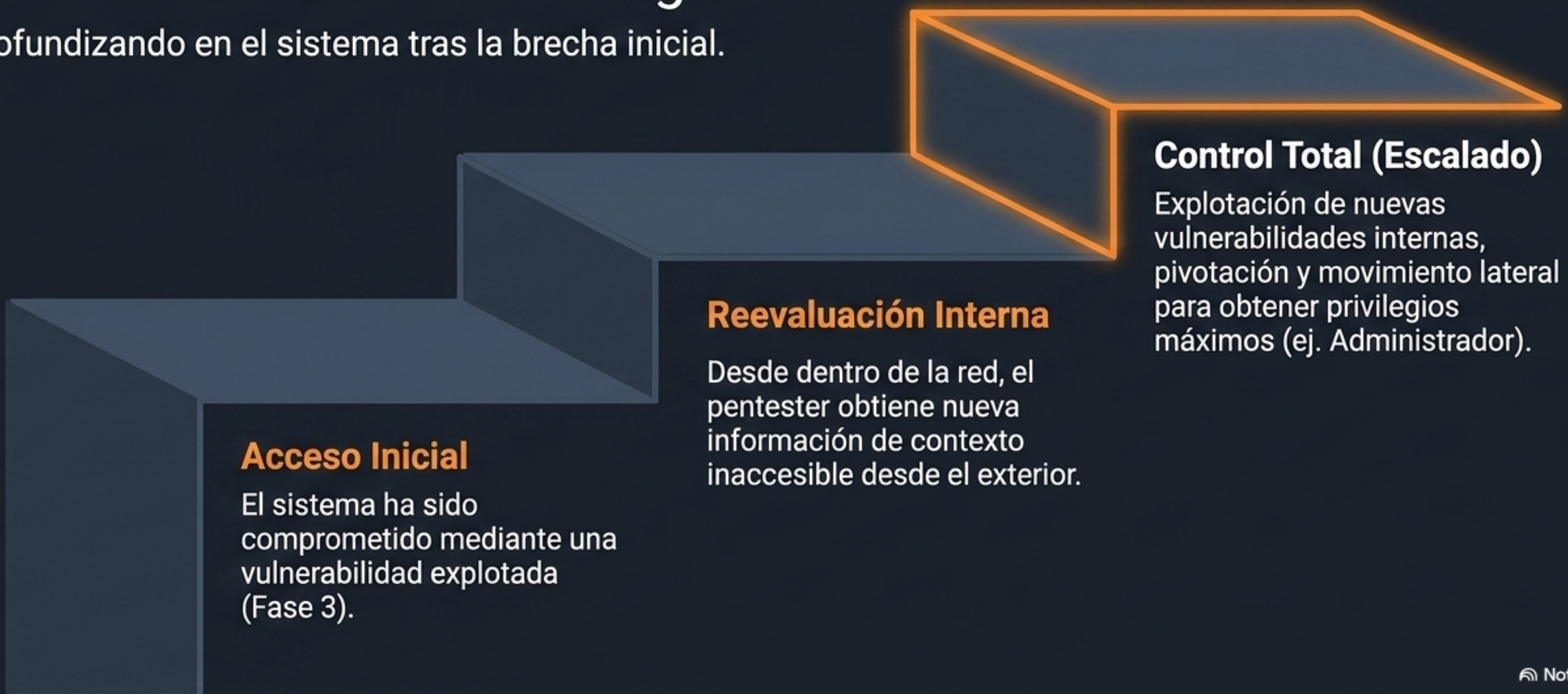
Las vulnerabilidades teóricas detectadas en la fase anterior son puestas a prueba mediante el desarrollo o uso de exploits específicos. Esto descarta falsas alarmas y mide el impacto real sobre el activo.



Fase 4 | Elevación

Fase 4: Elevación de Privilegios

Profundizando en el sistema tras la brecha inicial.



Acceso Inicial

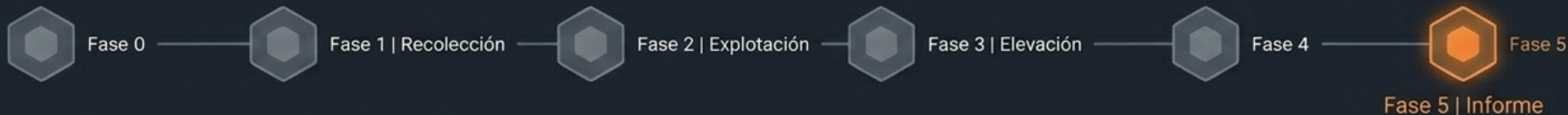
El sistema ha sido comprometido mediante una vulnerabilidad explotada (Fase 3).

Reevaluación Interna

Desde dentro de la red, el pentester obtiene nueva información de contexto inaccesible desde el exterior.

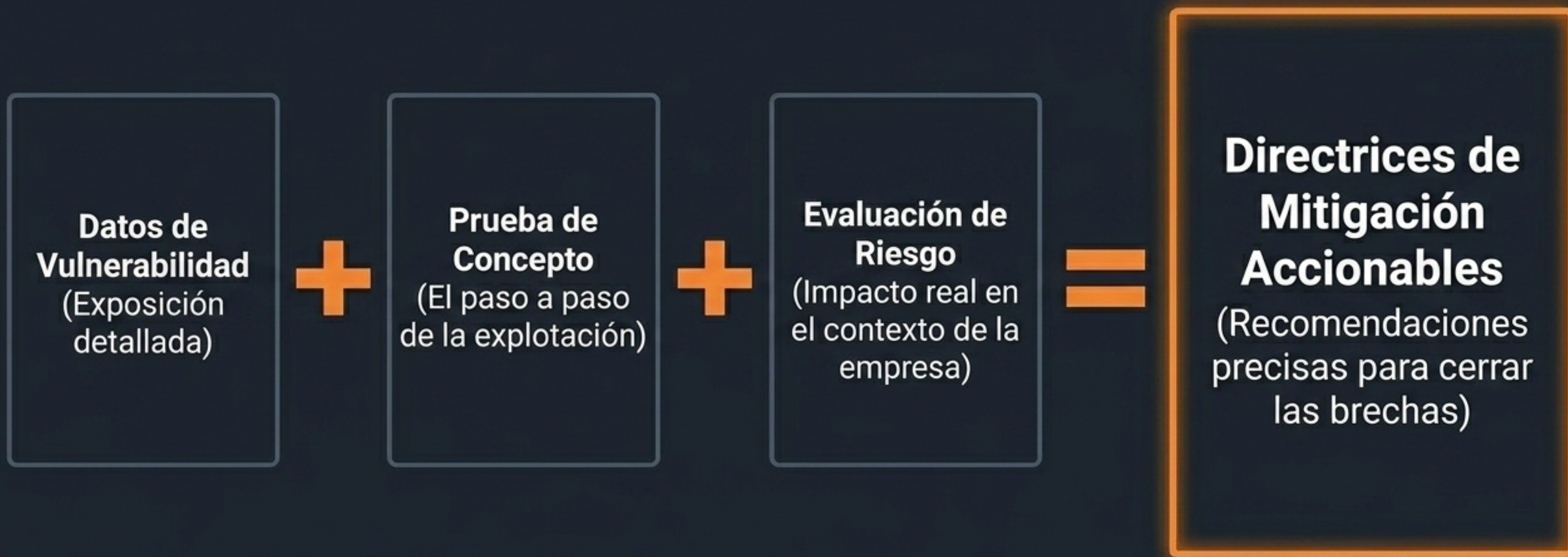
Control Total (Escalado)

Explotación de nuevas vulnerabilidades internas, pivotación y movimiento lateral para obtener privilegios máximos (ej. Administrador).



Fase 5: Documentación e Informe de Resultados

La traducción de la intrusión técnica en inteligencia de negocio.



El Mandato del Hacking Ético

Los tres pilares que diferencian una simple intrusión de una auditoría profesional.

El Rol del Auditor

El pentester busca mejorar constantemente para entregar un trabajo de calidad.

No soluciona las vulnerabilidades directamente, sino que propone las directrices expertas para resolverlas.

El Entregable Supremo

El informe de resultados es el activo de mayor valor.

Gran esfuerzo técnico carece de sentido si el cliente no puede entender y aplicar los resultados.

Máxima Confidencialidad

Durante el proceso, se expone información altamente crítica de la empresa.

Exige un manejo impecable de los datos hallados mediante cifrado, ofuscación y anonimización.